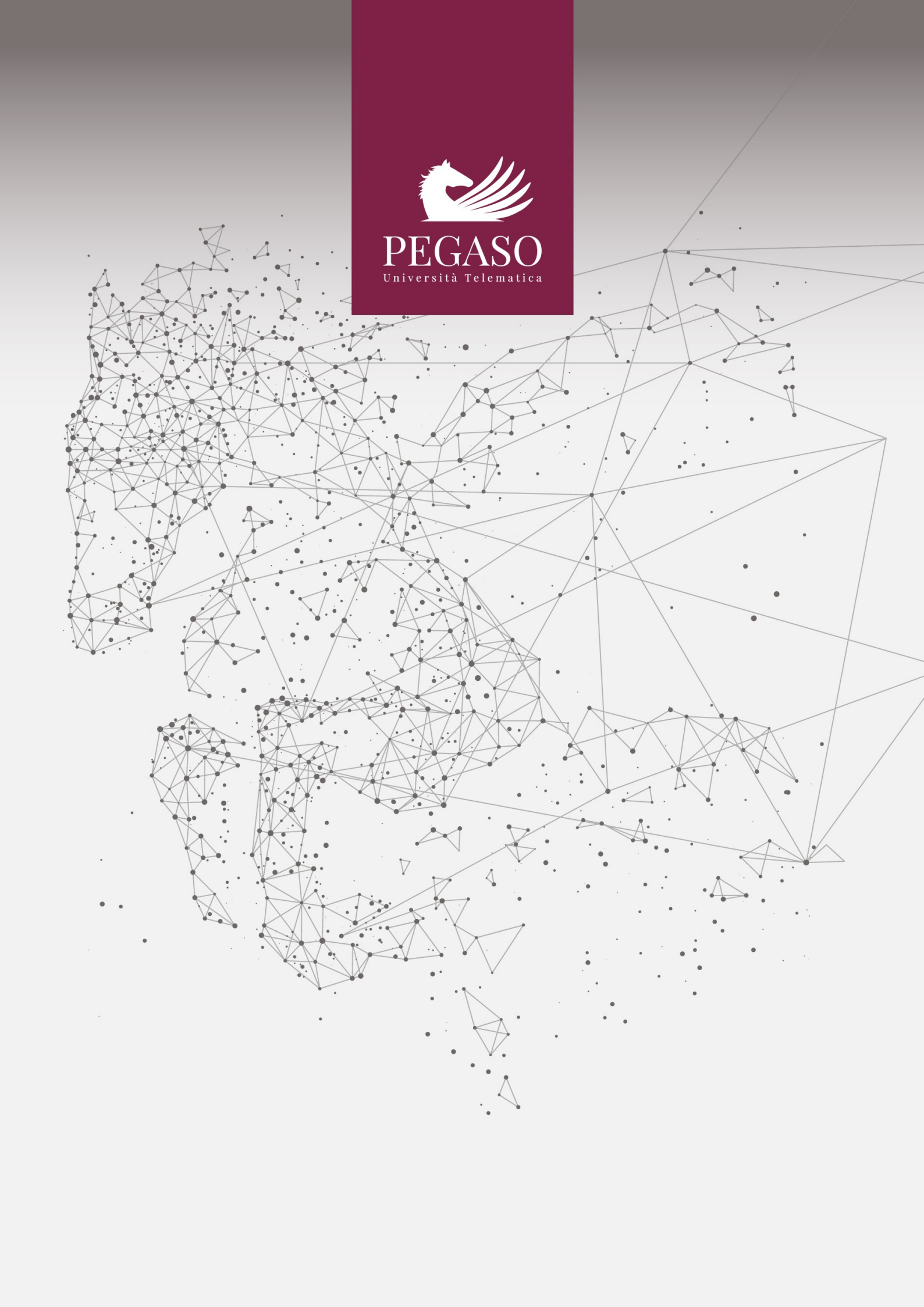

PEGASO
Università Telematica

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 SET: INTRODUZIONE 3
2 DOPPIA FIRMA 6
3 PAGAMENTI: RICHIESTA DI ACQUISTO 8
4 PAGAMENTI: AUTORIZZAZIONE DEL PAGAMENTO 11
5 PAGAMENTI: CATTURA DEL PAGAMENTO 13
BIBLIOGRAFIA 15

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 SET: introduzione

SET (Secure Electronic Transaction) è una specifica di crittografia aperta e di sicurezza progettata per proteggere le transazioni internet effettuate tramite carta di credito

Esso rappresenta un insieme di protocolli di sicurezza e di formati che consentono di impiegare in modo sicuro l'infrastruttura di pagamento tramite carta di credito su una rete aperta. SET soddisfa dei requisiti specifici attraverso la definizione di varie funzionalità e il coinvolgimento di differenti attori.

Vediamo intanto, nella tabella seguente, quali sono i principali requisiti e le corrispondenti funzionalità messe in campo:

REQUISITI	**FUNZIONALITA'**
Segretezza del pagamento e delle informazioni sugli ordini	Crittografia DES
Garanzia dell'integrità dei dati trasmessi	Firme digitali RSA e codici hash SHA-1
Garanzia che il possessore della carta di credito sia l'utente legittimo di un conto corrispondente	Firme digitali RSA e certificati digitali X509
Garanzia di interoperabilità fra vari software e provider di rete	Uso di protocolli e formati indipendenti dalla piattaforma hardware e dal sistema operativo

Gli attori che invece sono coinvolti sono i seguenti:

- *Titolare della carta di credito (Cardholder)*
- *Venditore (Merchant)*
- *Emettitore-[Banca] (Issuer)*: responsabile del pagamento

PEGASO Università Telematica

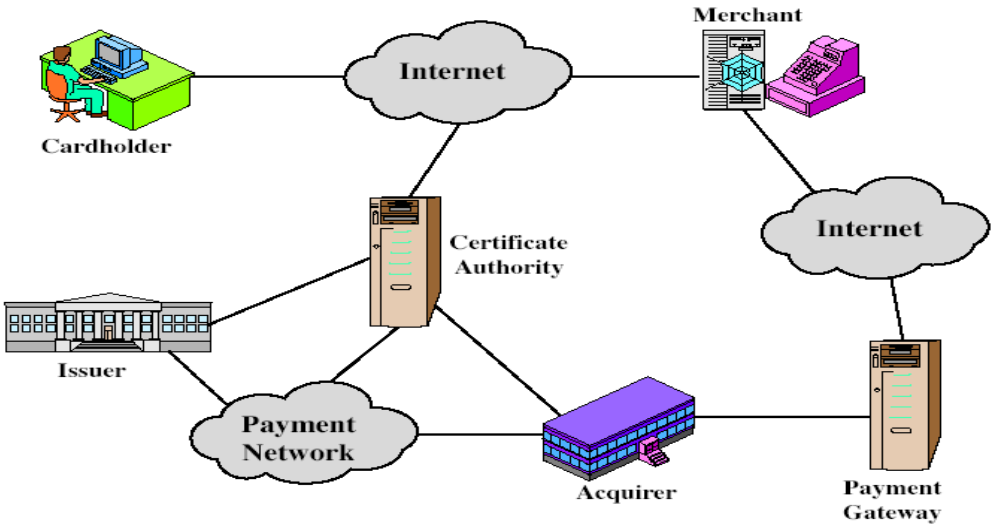
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

– *Acquisitore (Acquirer)* : istituzione finanziaria che tutela il venditore

– *Gateway di pagamento (Payment gateway)*: elabora i messaggi di pagamento per il venditore.

– *Autorità di certificazione (Certification Authority)*: emette i certificati

I collegamenti e relazioni fra i vari attori in gioco sono evidenziati nella figura sottostante.



Quando si effettua una transazione, sostanzialmente si eseguono una serie di passaggi successivi, vediamoli nel dettaglio così da avere un riferimento per progettare il protocollo SET.

1. Il cliente apre un conto (Visa, MasterCard)
2. Il cliente riceve un certificato digitale X.509 firmato dalla banca
3. I venditori hanno i propri certificati
4. Il cliente effettua un ordine
5. Il venditore viene verificato
6. L'ordine e il pagamento vengono inviati

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

7. Il venditore richiede l'autorizzazione del pagamento
8. Il venditore conferma l'ordine
9. Il venditore fornisce i beni o il servizio
10. Il venditore richiede il pagamento

PEGASO
Università Telematica

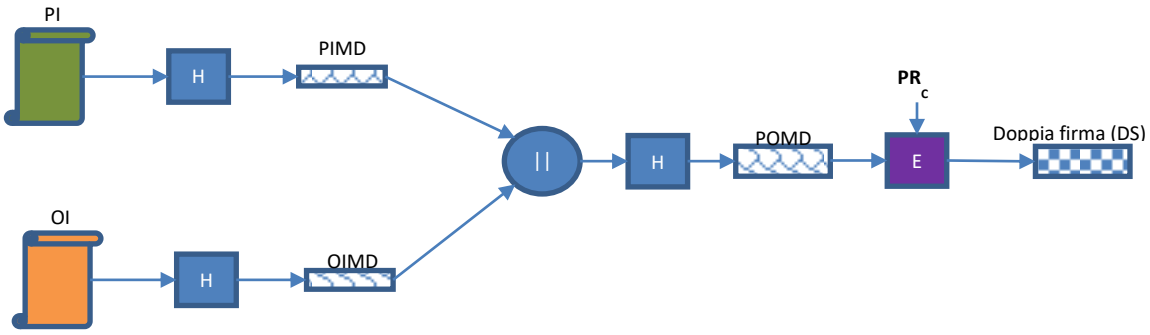
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2 Doppia firma

Il sistema SET si avvale di un meccanismo strategico ovvero il meccanismo della *Doppia Firma (DS – Digital Signature)* che consente di collegare due messaggi emessi dal cliente e destinati a due diversi destinatari

- Le informazioni dell'ordine (*OI, Order Information*) devono essere inviate al venditore ma non il numero di carta di credito.
- Le informazioni del pagamento (*PI, Payment Information*) devono essere inviate alla banca ma non i dettagli dell'ordine.

La Doppia Firma viene generata, come rappresentato in figura, attraverso l'uso congiunto di una funzione di hash (SHA-1) e della crittografia a chiave asimmetrica.



Le informazioni di pagamento (PI) e quelle relative all'ordine (OI) vengono separatamente trasformate tramite un hash crittografico così da ottenere due digest indicati rispettivamente con PIMD e OIMD. Tali digest sono concatenati e, a loro volta, trasformati nuovamente attraverso un hash fino a produrre un nuovo digest denominato POMD (Payment Order Message Digest) che viene firmato utilizzando la chiave privata PR_C del cliente. Quest'ultimo dato costituisce la doppia firma.

$$\mathbf{DS=E(PR_C,[H(H(PI)||H(OI))])}$$

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Al venditore e alla banca vengono inviati messaggi differenti in modo che entrambi possano svolgere le loro operazioni specifiche ma essendo a cono scienza soltanto di ciò che compete loro.

Il venditore riceve la doppia firma DS, le informazioni dell'ordine OI e l'hash PIMD, quindi può effettuare le seguenti due operazioni:

1. Calcolare H(PIMD||H(OI))
2. Decifrare la doppia firma usando la chiave pubblica del cliente $D(PU_C,DS)$

A questo punto può verificare la firma confrontando i due risultati.

Allo stesso modo, la banca riceve DS, le informazioni del pagamento PI e il codice hash OIMD e può a sua volta effettuare le seguenti due operazioni:

1. Calcolare H(H(PI)||OIMD)
2. Decifrare la doppia firma usando la chiave pubblica del cliente $D(PU_C,DS)$

e verificare la firma confrontando le due quantità ottenute.

Il venditore ha quindi ricevuto le informazioni dell'ordine OI e ha verificato la firma, la banca stessa ha ricevuto le informazioni di pagamento PI e ha verificato la firma.

Il cliente ha così collegato le informazioni di pagamento PI con quelle sull'ordine OI e può dimostrare il loro collegamento.

Qualora il venditore volesse alterare l'ordine a proprio vantaggio, dovrebbe realizzare un nuovo OI il cui valore hash deve però corrispondere con OIMD in possesso della banca: la funzione hash SHA-1 rende ciò praticamente impossibile!

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Pagamenti: richiesta di acquisto

La *richiesta di acquisto* costituisce la prima fase dell'elaborazione di un pagamento per un certo ordine. Essa stessa si suddivide in quattro fasi distinte:

- *Initiate Request*
- *Initiate Respone*
- *Purchase Request*
- *Purchase Response*

Initiate Request: inviato dal cliente al venditore

- Il cliente richiede i certificati del venditore e del gateway di pagamento
- Invia anche un ID della coppia request/response e un nonce per impedire come al solito attacchi replay.

Initiate Response: inviato dal venditore al cliente

- Invia il nonce inviato dal cliente, un altro nonce e un ID_T della transazione, il tutto cifrato con la propria chiave privata
- Include il suo certificato e quello del gateway di pagamento come da richiesta del cliente.

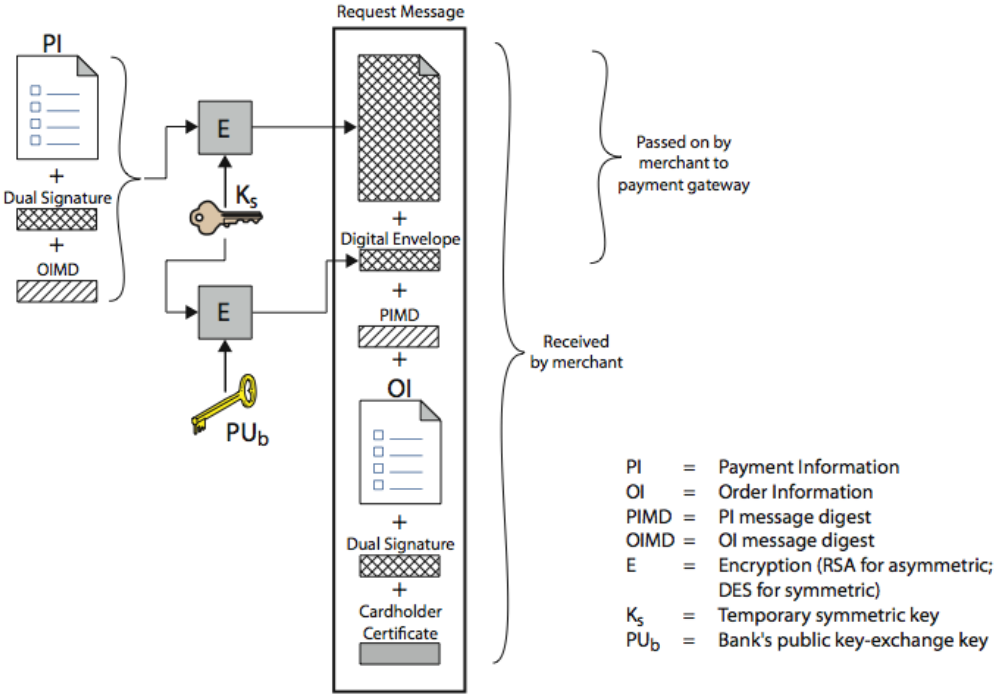
Purchase Request: inviato dal cliente al venditore

- Il cliente prima di tutto verifica con la CA i due certificati ricevuti
- Crea le informazioni OI e PI (entrambe contengono ID_T)
- Genera una chiave simmetrica monouso K_S con cui cifra la concatenazione di PI, dell'hash OIMD e della doppia firma (DS). Il risultato viene a sua volta concatenato con una bista digitale che contiene la chiave monouso

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

cifrata con la chiave pubblica PU_b del gateway di pagamento (vedi figura). Tale messaggio è destinato al gateway di pagamento a cui sarà inoltrato dal venditore stesso.

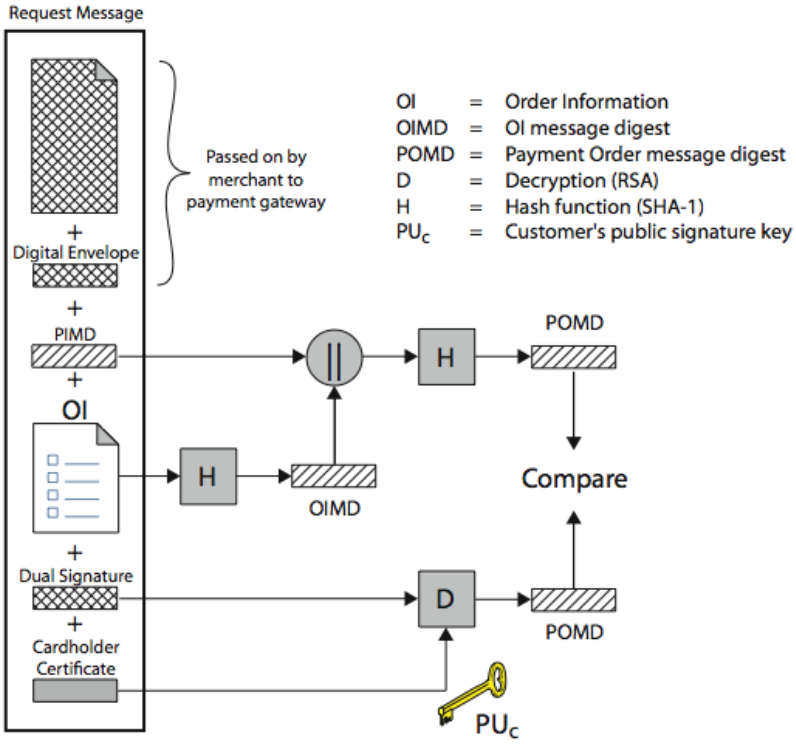


- Al messaggio destinato al gateway di pagamento, il cliente aggiunge le informazioni dell'ordine (OI), l'hash PIMD e la doppia firma (DS), nonché il proprio certificato.

Purchase Response: inviato dal venditore al cliente

- Il venditore verifica con la CA il certificato del cliente
- Verifica la doppia firma, elabora l'ordine e inoltra le informazioni di pagamento al gateway (vedi figura).
- Invia inoltre un blocco di conferma che contiene ID_T cifrato con la sua chiave privata e di nuovo il suo certificato.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

4 Pagamenti: autorizzazione del pagamento

L'*autorizzazione del pagamento* costituisce la seconda fase dell'elaborazione di un pagamento per un certo ordine. Essa garantisce che la transazione sia stata approvata dall'ente emettitore e che il venditore riceverà il pagamento

Essa si suddivide in due fasi:

– *Authorization Request*

– *Authorization Respone*

Authorization Request: inviato dal venditore al gateway di pagamento

- Inoltra il messaggio con le PI e la busta digitale ricevuta dal cliente
- Invia un blocco di autorizzazione che contiene ID_T firmato con la sua chiave privata e cifrato con una nuova chiave simmetrica monouso K_{vs} del venditore
- Invia una busta digitale contenente K_{vs} cifrata con la chiave pubblica del gateway
- Invia il suo certificato di firma, quello del cliente e il certificato per lo scambio di chiavi con il gateway

Authorization Response (1/2): il gateway esegue le verifiche

- Verifica i certificati
- Decifra la busta digitale inviata dal venditore, estrae K_{vs}, decifra il blocco di autorizzazione (contenente ID_T) e verifica la firma del venditore
- Decifra la busta digitale proveniente dal cliente, estrae K_s, decifra il blocco di pagamento e verifica la doppia firma.
- Verifica ID_T ricevuto dal venditore con quello contenuto nelle PI ricevute indirettamente dal cliente
- Richiede e riceve un'autorizzazione dall'emettitore

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Authorization Response (2/2): il gateway invia *Auth. Response* al venditore

- Invia un blocco di autorizzazione cifrato con la chiave privata del gateway, il tutto crittografato con una chiave simmetrica monouso K_{gs} , inoltre include una busta digitale contenente la chiave simmetrica K_{gs} cifrata con la chiave pubblica del venditore
- Invia un token di cattura del pagamento (fatto come il blocco precedente) che serve nella fase di «cattura del pagamento»
- Il proprio (gateway di pagamento) certificato

.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

5 Pagamenti: cattura del pagamento

La cattura del pagamento costituisce la terza fase dell'elaborazione di un pagamento per un certo ordine. Essa serve per l'ottenimento del pagamento e si suddivide in:

- *Capture Request*
- *Capture Respone*

Capture Request: inviato dal venditore al gateway

- Invia blocco di richiesta di cattura (contenente somma del pagamento e ID_T), firmato con la propria chiave privata e cifrato con la chiave pubblica del gateway.
- Reinvia il token ricevuto durante *Auth. Response*
- Invia il proprio certificato e quello del gateway

Capture Response (1/2): il gateway esegue le verifiche

- Decifra e poi verifica la firma sul blocco di cattura
- Decifra e poi verifica il token di cattura
- Esegue il confronto tra la richiesta di cattura e il token
- Invia una richiesta di liquidazione all'emettitore che esegue il trasferimento fondi a favore del venditore

Capture Response (2/2): il gateway invia *Capt. Response* al venditore

- Invia un blocco di risposta della cattura firmato con la sua chiave privata, insieme al suo certificato
- Il venditore memorizza tale ricevuta di pagamento

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: *Capitolo 17*.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).